

Área de Conocimiento de Tecnología de la Información y Comunicación

Auditoria de Sistemas

CASO PRÁCTICO COSO COBIT

Elaborado por:

Docente:

Br. Gerson Antonio
Valdivia

Br. Stephanie Lucía
Mora Chávez

Msc. Leonel Antonio Martínez Zuniga

Br. Haxell Antonio
Trejos Rodríguez

Br. Arleth del Rosario
Velásquez Gómez

Br. Alison Michelle
Navarro Goussen

28 de mayo, 2026
Managua, Nicaragua

ACTIVIDAD 1: CASO PRÁCTICO COBIT 2019

Caso: Empresa “TECHSOLUTIONS S.A.”

1. Identificación de riesgos de TI

No	Riesgo identificado	Impacto
1	Pérdida definitiva de datos críticos: Al no existir respaldos automáticos, cualquier falla puede causar pérdida irreversible de la información de clientes.	Alto (Pérdida financiera, daño reputacional y posibles problemas legales).
2	Accesos no autorizados y fuga de información: Compartir contraseñas elimina la trazabilidad y facilita el robo o alteración de datos por personal interno o externo.	Alto (Vulneración de la confidencialidad y la integridad de los datos).
3	Interrupción prolongada de las operaciones: Las fallas constantes en equipos y la falta de mantenimiento en servidores pueden paralizar las ventas y servicios.	Alto (Pérdida de ingresos, ineficiencia operativa).
4	Resolución ineficiente de problemas técnicos: La falta de soporte oportuno y de documentación de incidentes provoca que los mismos errores ocurran repetidamente.	Medio (Baja productividad del personal, insatisfacción del usuario).
5	Incumplimiento normativo y falta de gobernanza: Ausencia de políticas formales de seguridad informática.	Alto (Descontrol generalizado y vulnerabilidad ante ciberataques).

2. Relación de riesgos con procesos del dominio DSS de COBIT 2019

Riesgo	Proceso COBIT DSS relacionado
1. Pérdida definitiva de datos críticos	DSS04: Gestionar la Continuidad / DSS05: Gestionar los Servicios de Seguridad.
2. Accesos no autorizados y fuga de información	DSS05: Gestionar los Servicios de Seguridad / DSS06: Gestionar los Controles de los Procesos de Negocio.
3. Interrupción prolongada de las operaciones	DSS01: Gestionar las Operaciones.
4. Resolución ineficiente de problemas técnicos	DSS02: Gestionar las Peticiones y los Incidentes del Servicio / DSS03: Gestionar los Problemas.
5. Incumplimiento normativo y falta de gobernanza	DSS05: Gestionar los Servicios de Seguridad (alineado con la falta de políticas de protección).

3. Instrumento de recopilación de información

Tipo de instrumento: Lista de Verificación (Checklist) y Entrevista estructurada.

MODELO DE LISTA DE VERIFICACIÓN

Pregunta	Sí	No	Observación
¿Existen respaldos automáticos y se verifican regularmente?		X	Solo se hacen de forma manual esporádicamente o no se hacen.
¿Se cambian periódicamente las contraseñas y son individuales?		X	Los usuarios comparten credenciales genéricas.
¿Existe y se difunde una política de seguridad informática?		X	Inexistencia de lineamientos formales documentados.
¿Se registran y documentan los incidentes de TI (sistema de tickets)?		X	Los reportes se hacen de manera verbal sin trazabilidad.
¿Los usuarios reciben soporte técnico en tiempos establecidos (SLA)?		X	Hay quejas constantes sobre la lentitud del soporte.
¿Se realiza mantenimiento preventivo programado a los servidores?		X	Solo se aplica mantenimiento correctivo cuando fallan.

4. Informe preliminar de auditoría

- **Objetivo de la auditoría:** Evaluar los controles del dominio DSS (Entregar, Dar Servicio y Soporte) de COBIT 2019 en TECHSOLUTIONS S.A. para asegurar la continuidad operativa, la seguridad de la información y la calidad del soporte técnico.
- **Alcance:** Área de operaciones tecnológicas, soporte a usuarios, gestión de infraestructura (servidores y equipos) y políticas de seguridad informática de la empresa.
- **Hallazgos:** Ausencia de políticas de seguridad documentadas, inexistencia de respaldos automatizados, práctica generalizada de compartir contraseñas, falta de mantenimiento preventivo en servidores y nula gestión documental de incidentes.
- **Riesgos encontrados:** Alta probabilidad de fuga o pérdida de datos de clientes, interrupción de los servicios de ventas por caída de servidores, vulneraciones de seguridad por accesos no rastreables e ineficiencia en la resolución de problemas técnicos.
- **Recomendaciones:** Diseñar e implementar una Política de Seguridad de la Información, automatizar los backups en la nube o en servidores redundantes, implementar un sistema de tickets (Mesa de Ayuda) para soporte, establecer roles y usuarios únicos en el Active Directory, y programar un calendario de mantenimiento preventivo.
- **Conclusión preliminar:** El entorno tecnológico de TECHSOLUTIONS S.A. presenta debilidades críticas en sus operaciones diarias y soporte. No existe un gobierno de TI efectivo, lo que pone en riesgo la continuidad del negocio y la integridad de la información de sus clientes.

ACTIVIDAD 2: CASO PRÁCTICO COSO

Caso: Empresa “COMERCIAL NICARAGUA”

1. Componentes COSO afectados

Situación encontrada	Componente COSO
Accesos sin control	Actividades de control (Falta de segregación de funciones) e Información y Comunicación .
Falta de supervisión	Supervisión y monitoreo (Actividades de monitoreo continuo).
Falta de capacitación	Ambiente de control (Compromiso con la competencia profesional).
Antivirus desactualizado	Evaluación de riesgos y Actividades de control .
Registros de inventario con inconsistencias	Actividades de control (Revisiones de desempeño, validación de datos).

2. Clasificación de riesgos

Riesgo	Tipo de riesgo
Pérdida de información	Operativo / Tecnológico
Accesos no autorizados	Seguridad / Fraude
Inconsistencias contables y de inventario	Financiero / Operativo
Infección por malware/Ransomware	Tecnológico / Seguridad
Errores humanos por falta de pericia	Operativo / Recursos Humanos

3. Propuesta de controles internos

Debilidad	Control recomendado
Usuarios con acceso total	Implementar roles y perfiles basados en el principio de menor privilegio (RBAC).
No hay monitoreo	Implementar bitácoras (Logs) automatizadas y alertas de auditoría.
Antivirus desactualizado	Implementar gestión centralizada de Endpoint Protection con actualizaciones automáticas.
Inconsistencias en inventario	Realizar conciliaciones periódicas y validaciones de entrada de datos en el sistema.
Falta de capacitación	Establecer un programa de capacitación continuo en uso de sistemas y concientización en seguridad.

4. Conclusiones

- **¿Qué importancia tiene COSO en la auditoría informática?**

Proporciona una visión integral y gerencial de la empresa. Asegura que los controles técnicos de TI no estén aislados, sino que respondan a un entorno de control corporativo, mitigando riesgos que puedan afectar los estados financieros y los objetivos operativos.

- **¿Cómo ayuda COBIT en el gobierno de TI?**

Proporciona un marco de trabajo que traduce los objetivos estratégicos de la empresa en objetivos de TI específicos. Ayuda a definir procesos, medir el rendimiento, asignar responsabilidades y asegurar que la tecnología genere valor mientras se optimizan los recursos y se minimizan los riesgos.

- **¿Por qué deben integrarse ambos marcos?**

Porque se complementan de manera ideal. COSO ofrece el "qué" a nivel corporativo (la estructura macro de control interno y gestión de riesgos), mientras que COBIT proporciona el "cómo" a nivel tecnológico (las prácticas específicas, procesos y métricas para gobernar y auditar la TI). Juntos aseguran que la tecnología apoye directamente la misión de la empresa bajo un control riguroso.

ACTIVIDAD 3: ANÁLISIS COMPARATIVO COBIT VS COSO

Aspecto	COBIT 2019	COSO
Enfoque principal	Gobierno y Gestión de las Tecnologías de la Información.	Control Interno Integral y Gestión de Riesgos Corporativos.
Área de aplicación	Departamentos de TI, sistemas de información e infraestructura tecnológica.	Toda la organización (Finanzas, Operaciones, Cumplimiento, Estrategia).
Gestión de riesgos	Se enfoca en riesgos tecnológicos (ciberseguridad, fallas de sistemas, pérdida de datos).	Se enfoca en el riesgo empresarial general (ERM), incluyendo fraudes y riesgos financieros.
Gobierno de TI	Es su núcleo y razón de ser; alinea la TI con el negocio.	Lo aborda de forma indirecta, considerándolo parte del ambiente de control global.
Control interno	Define controles específicos a nivel de procesos, aplicaciones e infraestructura de TI.	Proporciona un marco conceptual de 5 componentes aplicable a cualquier área de la empresa.
Seguridad de información	Posee procesos detallados (ej. dominio DSS) sobre cómo proteger la información operativa y estratégicamente.	La exige como una actividad de control para proteger los activos y asegurar la fiabilidad de la información.

ACTIVIDAD 4: DESARROLLO DE PROPUESTAS DE MEJORA

a) 5 Recomendaciones técnicas

1. **Implementar un sistema de Backups automatizado** (regla 3-2-1) en la nube y medios físicos.
2. **Configurar Active Directory** o un sistema IAM (Identity and Access Management) para forzar usuarios únicos y aplicar roles restrictivos en el sistema de facturación.
3. **Desplegar un EDR/Antivirus corporativo centralizado** para garantizar que ningún equipo opere con firmas de virus desactualizadas.
4. **Implementar una herramienta de Mesa de Ayuda (Helpdesk/Ticketing)** (ej. GLPI, osTicket) para registrar, clasificar y dar seguimiento a los incidentes técnicos.
5. **Activar auditoría y logs en bases de datos y sistemas operativos** para tener trazabilidad de quién modifica inventarios o configuraciones críticas.

b) 5 Recomendaciones administrativas

1. **Redactar y oficializar una Política de Seguridad de la Información**, exigiendo firmas de acuerdos de confidencialidad (NDA) al personal.
2. **Definir y documentar una Política de Contraseñas Seguras** (cambio cada 90 días, longitud mínima, prohibición de compartirlas).
3. **Establecer un Plan Anual de Capacitación** obligatorio para todos los usuarios sobre el uso correcto del sistema y buenas prácticas de ciberseguridad.
4. **Diseñar un Cronograma Anual de Mantenimiento Preventivo** para equipos de cómputo y servidores.
5. **Establecer comités de revisión de inventarios y auditorías cruzadas**, segregando las funciones del personal que registra la facturación y el que controla la bodega.

c) Plan básico de mejora

Actividad	Responsable	Tiempo
1. Creación y aprobación de Políticas de Seguridad de TI.	Gerencia General / Gerente de TI	1 mes
2. Configuración de usuarios individuales, perfiles y roles en sistemas.	Administrador de Sistemas	2 semanas
3. Implementación de respaldos automatizados y antivirus centralizado.	Soporte de Infraestructura / TI	3 semanas
4. Despliegue de sistema de tickets para registro de incidentes.	Jefe de Soporte Técnico	2 semanas
5. Ejecución del primer ciclo de capacitación al personal.	Recursos Humanos / Área de TI	1 mes
6. Ejecución de mantenimiento preventivo a servidores y equipos.	Área de TI / Proveedor externo	1 mes